

FRAUD READINESS ADVISORY

Essential Fraud Readiness Review

An evidence-linked view of reported readiness, material risk, control priorities and leadership decisions.

PREPARED EXCLUSIVELY FOR

Vhutshilo Foods Manufacturing (Pty) Ltd

Report reference RPT-MKFRS-V12-ESS-VHUTSHILO-V1

Generated 24 August 2026

Essential package

CONFIDENTIAL · INTERNAL LEADERSHIP USE

Contents

Executive summary	3
What the result means	4
Domain overview	6
Priority findings, contradictions and scenarios	7
Priority risks	14
Leadership decisions and roadmap	17
Proof requirements	21
Methodology, limitations and next steps	22
Appendix: supporting material	22
Complete supporting detail	22
E1. Supporting control actions	22
E2. Definitions and score basis	25

Executive summary

Fraud controls are not yet consistently embedded.

Reported readiness

43

out of 100

Developing

Overall readiness position

Vhutshilo Foods Manufacturing's assessed fraud-readiness score is 43.33 out of 100 and the maturity band is Developing. The profile shows established capability in whistleblowing and reporting culture (Domain D6 is a relative strength), while several operational and digital controls sit materially lower in the profile. Domains with the most constrained positions include Digital and Identity Fraud Risk, Fraud Risk Identification, Operational Fraud Controls, Fraud Detection Capability and Continuous Improvement and Fraud Risk Monitoring. This combination places the organisation on a clear improvement path: preserve the existing reporting-strength foundation and close the process-, supplier- and access-related gaps that enable diversion or concealment.

Assurance boundary: this assessment reflects management's responses mapped to the MK method; it is strategic fraud-risk analysis and control design, without verification of operating effectiveness by this review.

What is shaping the readiness position

The recorded position is shaped by a small set of connected themes that together explain where attention should land. Identity and access governance is flagged because privileged and ordinary access controls are not fully formalised, creating a potential route to alter records. Fraud governance and risk-management discipline is constrained by informal, reactive mapping of fraud scenarios to processes so that control ownership and treatment are not always explicit. Supplier and payment integrity is partly designed but inconsistent, producing activation and verification gaps that could be exploited. Incident response and evidence integrity are at an initial or ad hoc stage, weakening containment when a concern arises. Finally, monitoring, escalation and detection coverage is partly designed, so unusual activity may not trigger timely challenge. These themes interact: weak process-level risk mapping makes it harder to prioritise monitoring rules; gaps in supplier checks amplify payment-diversion risk; and incomplete evidence-preservation undermines learning when incidents are raised.

What this means for management

The score is a starting point for organised action rather than a terminal verdict. Management should convert the relative strength in reporting into operational improvements by assigning clear accountable owners, completing per-process fraud mapping, and sequencing the supplier, access and monitoring fixes that interrupt the most direct exposure pathways. A disciplined programme with named accountability and short target windows will convert the Developing maturity into measurable improvements.

COVERAGE

100%

CRITICAL GAPS

6

MAJOR GAPS

3

Assessment scope and limitations

APPLICABLE CONTROLS

CONTROL VISIBILITY

EXCLUDED AREAS

UNCERTAINTY RESPONSES

60

100%

8

0

This is a provisional result. Differences in assessed scope or uncertainty may limit comparison with other assessments.

4 control areas were completed using the assessment's oversight question set rather than the standard question set. They remain in the scored scope. Excluded areas are outside the assessed scope and are not treated as weaknesses.

The aggregate result and its ten underlying domains

The Developing result describes the reported self-assessment position. It does not, by itself, establish operating effectiveness.

Fraud Leadership and Governance 42 Developing	Fraud Risk Identification 39 Reactive	Operational Fraud Controls 41 Developing	Fraud Detection Capability 41 Developing	Fraud Incident Response 44 Developing
Whistleblowing and Reporting Culture 61 Structured	Third-Party and Supply Chain Fraud Risk 47 Developing	Digital and Identity Fraud Risk 38 Reactive	Fraud Culture and Awareness 57 Developing	Continuous Improvement and Fraud Risk Monitoring 41 Developing

What the result means

The recorded conditions requiring first attention

CRITICAL CONTROL GAP · FRAUD RISK IDENTIFICATION

Fraud risks are mapped to the organisation's important processes.

CRITICAL CONTROL GAP · OPERATIONAL FRAUD CONTROLS

The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf.

CRITICAL CONTROL GAP · OPERATIONAL FRAUD CONTROLS

System and data access is granted against current role requirements.

CRITICAL CONTROL GAP · FRAUD DETECTION CAPABILITY

Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.

CRITICAL CONTROL GAP · FRAUD INCIDENT RESPONSE

Evidence linked to suspected fraud is identified, preserved and handled appropriately.

Access to sensitive systems, administrator rights and confidential data is restricted.

Where a strong average can still hide a real gap

MATURITY CEILING · FRAUD RISK IDENTIFICATION

Fraud risks are mapped to the organisation's important processes.

This rule sets a maximum maturity of **Developing**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · OPERATIONAL FRAUD CONTROLS

Supplier onboarding verifies business identity, ownership and initial banking information before approval.

This rule sets a maximum maturity of **Structured**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · CROSS-DOMAIN

Three or more critical controls scored 0, 1 or 2.

This rule sets a maximum maturity of **Developing**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · FRAUD RISK IDENTIFICATION

Core domain Fraud Risk Identification scored below 40.

This rule sets a maximum maturity of **Developing**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · FRAUD LEADERSHIP AND GOVERNANCE

Core domain Fraud Leadership and Governance scored below 60.

This rule sets a maximum maturity of **Structured**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

Management response: see the leadership roadmap section for accountable executive mandates, escalation authority and the fraud-risk implementation and control-effectiveness review cadence.

A domain score is an average. It can still contain one specific control that is materially weaker than the others feeding into the same number. The purpose of this report is to surface that unevenness so leadership does not treat the overall score as a substitute for control-level attention.

Domain overview

The systemic pattern

The systemic constraint beneath the assessed position is a governance-to-execution gap: organisation-level intent and some pockets of capability exist, but process-level mapping, ownership and consistent operating proofs are missing. The assessment records fraud risks as mapped only informally and reactively at process level, which means specific diversion routes do not consistently have named treatment owners or evidence of controls. This underpins the other weaknesses: supplier-onboarding checks and supplier-bank verification are partly designed and inconsistently evidenced, privileged and role-based access governance is informal or partly designed, analytics and rule-based detection are not fully matured, and evidence-preservation remains ad hoc. Together these create conditional pathways where value can be redirected (through suppliers or payments), records can be altered (via excess privileged or stale access), and suspected matters can be weakened or lost (because evidence and incident-response rules are not consistently applied). Leadership should therefore prioritise the connected control and governance decisions that close ownership, introduce independent verification points and protect evidence from the moment a concern is raised.

Foundations: ownership, awareness and reporting culture

Executive ownership, risk identification, workforce awareness and safe reporting.

Fraud Leadership and Governance

42/100

Developing reported position.

Fraud Risk Identification

39/100

Reactive reported position.

Critical condition: Fraud risks are mapped to the organisation's important processes.

Fraud Culture and Awareness

57/100

Developing reported position.

Whistleblowing and Reporting Culture

61/100

Structured reported position.

Operational defence: controls, detection and third parties

Day-to-day prevention, detection and supplier-facing control operation.

Operational Fraud Controls Developing reported position. Priority condition: The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf. Critical condition: System and data access is granted against current role requirements.	41/100
Fraud Detection Capability Developing reported position. Priority condition: Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.	41/100
Third-Party and Supply Chain Fraud Risk Developing reported position.	47/100

Response and evolution: incidents, digital risk and improvement

Incident response, digital and identity defence, and continuous control improvement.

Fraud Incident Response Developing reported position. Priority condition: Evidence linked to suspected fraud is identified, preserved and handled appropriately.	44/100
Digital and Identity Fraud Risk Reactive reported position. Priority condition: Access to sensitive systems, administrator rights and confidential data is restricted.	38/100
Continuous Improvement and Fraud Risk Monitoring Developing reported position.	41/100

PRIORITY FINDINGS, CONTRADICTIONS AND SCENARIOS

Priority findings, contradictions and scenarios

Role distinction: Control owner identifies the role responsible for implementing or operating the control. Accountable executive identifies the executive role responsible for sponsorship, decision rights and escalation. The two roles may legitimately differ.

Value diversion through supplier and payment processes

Supplier onboarding and bank-detail verification have been partly designed but are inconsistent. The practical consequence is a supplier or payment instruction pathway that can be used to redirect value before an independent challenge occurs. The approved treatment is explicit: require a pre-activation supplier checklist, independent verification of registration and bank ownership, beneficial-owner and conflict screening, risk rating and a blocked supplier-record activation until a second reviewer signs. Management must make independent verification before any supplier or bank change takes effect; without that, the pattern of unverified activations and last-minute bank changes will remain unchallenged.

Weak challenge at identity, transaction and sensitive-change points

Analytics, rules and data checks to identify suspicious transactions and control exceptions have been partly designed but are incomplete. That gap means unusual activity, approval anomalies or late supplier-bank changes can pass without timely detection. The practical control response is a maintained rule catalogue tied to named fraud scenarios, reconciled data sources, routine tuning and defined reviewing roles. Management should institute a defined monitoring cycle with a named owner for exception review and escalation; absent that cycle, exceptions may not receive the timely challenge required to prevent or limit loss.

Limited containment and learning after suspected fraud

Evidence identification, preservation and chain-of-custody processes are informal or reactive. When a suspected matter arises, incomplete preservation and transfer processes increase the risk that records are lost, altered or become unusable for investigation or recovery. The target control response is an evidence register opened for material cases, trained custodians creating forensic copies or sealed originals, recorded integrity checks and access-restricted repositories. Management must establish a defined intake and preservation route from first report; without that, suspected matters cannot be reliably contained or converted into organisational learning.

Additional material control pattern

A group of related material observations remains relevant to the priority set: privileged-access governance is informal; role-based access is partly designed; conflict-of-interest declaration and management in supplier contexts is informal or reactive; and workforce awareness of reporting channels is partly designed. Individually these controls matter; together they create an environment where excess access, unmanaged supplier relationships and gaps in declarations can combine to let value diversion remain undetected. Management's completion test for this group is named privileged accounts with periodic recertification, consistent role-to-access matrices with segregation-of-duties exception handling, annual and on-change conflict declarations for roles that influence suppliers, and tested reporting channels so staff know how to raise concerns.

MATERIAL FINDING 1

MATURITY CONSTRAINT

Fraud Risk Identification: Fraud risks are mapped to the organisation's important processes.

DOMAIN

Fraud Risk Identification

DIAGNOSIS

Process-level fraud risk mapping was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The Risk / compliance accountable owner must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.

ASSESSED CONTROL STATE

Fraud risks are mapped to the organisation's important processes.
— Informal / reactive

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Risk / compliance accountable owner with named process owners

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

IMPLEMENTATION

Moderate difficulty · 90 days

MATERIAL FINDING 2

MATURITY CONSTRAINT

Operational Fraud Controls: The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf.

DOMAIN

Operational Fraud Controls

DIAGNOSIS

Supplier-onboarding verification was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks supplier-record activation until a second reviewer signs; the vendor master retains the evidence package.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf. — Partly designed

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Procurement / Vendor Master

IMPLEMENTATION

Moderate difficulty · 60 days

MATERIAL FINDING 3

PRIORITY CONTROL WEAKNESS

Digital and Identity Fraud Risk: Access to sensitive systems, administrator rights and confidential data is restricted.

DOMAIN

Digital and Identity Fraud Risk

DIAGNOSIS

Privileged and administrator access governance was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

IT Security must maintain a complete sensitive-access inventory, require named identities and strong authentication, enforce least privilege and session logging, and remove access when the business justification ends; periodic recertification is handled by the separate access-review control.

ASSESSED CONTROL STATE

Access to sensitive systems, administrator rights and confidential data is restricted. — Informal / reactive

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Identity and Access Management

ACCOUNTABLE EXECUTIVE

Technology / security accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

IMPLEMENTATION

High difficulty · 60 days

MATERIAL FINDING 4

PRIORITY CONTROL WEAKNESS

Fraud Incident Response: Evidence linked to suspected fraud is identified, preserved and handled appropriately.

DOMAIN

Fraud Incident Response

DIAGNOSIS

Fraud evidence preservation and chain of custody was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.

ACCOUNTABLE EXECUTIVE

Legal / investigations accountable owner / Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Evidence linked to suspected fraud is identified, preserved and handled appropriately. — Informal / reactive

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Investigation lead / Evidence custodian

IMPLEMENTATION

High difficulty · 60 days

MATERIAL FINDING 5

PRIORITY CONTROL WEAKNESS

Operational Fraud Controls: System and data access is granted against current role requirements.

DOMAIN

Operational Fraud Controls

DIAGNOSIS

Role-based user-access governance was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

System owners must maintain a current role-to-access matrix, require business-owner approval against the requester's current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.

ASSESSED CONTROL STATE

System and data access is granted against current role requirements. — Partly designed

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Business system owners

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

IMPLEMENTATION

Moderate difficulty · 60 days

MATERIAL FINDING 6

PRIORITY CONTROL WEAKNESS

Fraud Detection Capability: Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.

DOMAIN

Fraud Detection Capability

DIAGNOSIS

Analytics and rule-based detection was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The monitoring owner must maintain a rule catalogue in which every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role; tests include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering; results reconcile to source control totals and rules are tuned monthly from confirmed true and false positives.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner / Technology / security accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions. — Partly designed

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Fraud analytics owner

IMPLEMENTATION

High difficulty · 90 days

MATERIAL FINDING 7

CROSS-DOMAIN DEPENDENCY

Third-Party and Supply Chain Fraud Risk: Employees are required to disclose and manage conflicts of interest involving suppliers or third parties.

DOMAIN

Third-Party and Supply Chain Fraud Risk

DIAGNOSIS

Conflict of interest declaration and management was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

ASSESSED CONTROL STATE

Employees are required to disclose and manage conflicts of interest involving suppliers or third parties. — Informal / reactive

WHY IT MATTERS

This recorded response and its surrounding exposure make the control materially relevant.

RECOMMENDED CONTROL

The compliance owner must require annual and on-change declarations from every employee able to influence supplier selection, contracting, receipting or payment, covering directorships, shareholdings, family relationships and outside interests; declarations are tested against the vendor master for matching surnames, addresses, contact details and bank accounts, and every declared or detected conflict receives a documented management action such as recusal, reassignment or enhanced review, recorded in a conflict register.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner / Legal / investigations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

CONTROL OWNER

Compliance with Human Resources

IMPLEMENTATION

Moderate difficulty · 60 days

MATERIAL FINDING 8

CROSS-DOMAIN DEPENDENCY

Whistleblowing and Reporting Culture: Employees know how to recognise suspected fraud and use the reporting channel.

DOMAIN

Whistleblowing and Reporting Culture

DIAGNOSIS

Workforce ability to use the reporting channel was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The ethics owner must publish channel instructions covering how to access it by phone and web, what information helps, whether anonymity is available, what feedback the reporter can expect and the protection from retaliation, in the languages and formats used across operating locations; the channel is tested at least annually with a live submission confirming intake, acknowledgement and case creation, and awareness is measured with targeted follow-up where low.

ACCOUNTABLE EXECUTIVE

People / workforce accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Employees know how to recognise suspected fraud and use the reporting channel. — Partly designed

WHY IT MATTERS

This recorded response and its surrounding exposure make the control materially relevant.

CONTROL OWNER

Ethics / Compliance lead

IMPLEMENTATION

Low difficulty · 60 days

Contradictions

CONTRADICTION 1

Operational and privileged-access weaknesses indicate one systemic access-governance issue

WHAT THE ASSESSMENT SHOWS

Digital and Identity Fraud Risk — Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort; Operational Fraud Controls — Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

WHY IT MATTERS

Excess access across ordinary and privileged environments can create an end-to-end manipulation and concealment route.

LEADERSHIP VERIFICATION

Is one complete identity, role and recertification population used across ordinary and privileged access reviews?

Scenarios and assurance tests

Conditional exposure pathways

The scenarios below are conditional illustrations of how the recorded findings can combine into a material pathway. They are management tests, not allegations.

SUPPLIER OR PAYMENT INSTRUCTION IS DIVERTED THROUGH A COMPROMISED OR FICTITIOUS RELATIONSHIP

This pathway begins when supplier onboarding or bank-detail changes are processed without independent verification. The current environment records supplier onboarding as partly designed and supplier management as handled by an external provider, which creates an entry point where a credible-looking bank-detail change or fictitious supplier can be activated shortly before payment. Warning indicators include a bank-detail change close to a payment date, a supplier activated before full verification, or ownership/conflict matches left unresolved. Immediate containment is to pause the affected supplier or payment instruction, independently confirm the trusted beneficiary details and preserve the approval trail. Longer-term response is implementation of the procurement pre-activation checklist, independent registration and bank verification, dual approval and vendor-master evidence retention.

PRIVILEGED ACCESS IS USED TO ALTER A VALUE-BEARING RECORD, ENTITLEMENT OR AUDIT TRAIL

This pathway begins where privileged and administrator access is informal or not subject to consistent recertification. An account that was justified for one purpose or location can be used across distributed operations to change records, entitlements or audit trails without a single owner reviewing entitlements end-to-end. Warning indicators include missed quarterly reviews, unassigned privileged accounts, leaver access not removed within service levels or unusual record changes. Immediate containment is to suspend or restrict the affected entitlement, preserve access and audit logs, and route the change for accountable review. The longer-term response is adoption of least-privilege controls, named privileged-account registers, continuous logging and quarterly independent recertification with event-driven removals.

RECORDS OR REPORTING ARE WEAKENED AFTER A SUSPECTED FRAUD MATTER, ALLOWING EXPOSURE TO REPEAT

This pathway unfolds when evidence and incident-handling are ad hoc. A suspected matter at one site generates records locally, and without a mandated severity and custody decision those records may remain uncontrolled, become unavailable, or be altered before central triage. Warning indicators include unexplained custody gaps, unavailable records, or a severity/containment decision overdue. Immediate containment is to open an incident record, preserve relevant records under controlled custody and assign a named containment and investigation owner. Long-term response is implementation of a protected reporting route, severity-based escalation, formalised evidence preservation and periodic review to prevent repeat exposure.

Priority risks

RISK 1 · FRAUD RISK IDENTIFICATION

CRITICAL

Organisation-level risk statements hide process-level opportunity, so a specific diversion route such as manipulation of a value-bearing adjustment is never mapped to a control owner.

Because the self-assessment records "Fraud risks are mapped to the organisation's important processes" as "Informal / reactive"; the expected control standard is therefore not yet met, there is a risk that organisation-level risk statements hide process-level opportunity, so a specific diversion route such as manipulation of a value-bearing adjustment is never mapped to a control owner. Consequence pathway: Material process exposures can remain without explicit control ownership or treatment; Unmapped process-level fraud routes can leave value diversion or loss outside targeted controls.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Fraud Risk Identification: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort

REQUIRED TREATMENT

The Risk / compliance accountable owner must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

TARGET PERIOD

90 days

RISK 2 · FRAUD DETECTION CAPABILITY

CRITICAL

Partly designed detection can leave material anomalies outside consistent data-driven review.

Because the self-assessment records "Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions" as "Partly designed"; the expected control standard is therefore not yet met, there is a risk that Partly designed detection can leave material anomalies outside consistent data-driven review. Consequence pathway: Alert backlogs can conceal important anomalies; unreviewed exceptions can allow losses to compound.

LIKELIHOOD

Moderate — Critical-control, scenario or dependency evidence supports a Moderate qualitative likelihood, not a statistical probability.

CURRENT CONTROL POSITION

Fraud Detection Capability: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner / Technology / security accountable owner

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

REQUIRED TREATMENT

The monitoring owner must maintain a rule catalogue in which every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role; tests include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering; results reconcile to source control totals and rules are tuned monthly from confirmed true and false positives.

TARGET PERIOD

90 days

RISK 3 · FRAUD INCIDENT RESPONSE

CRITICAL

Fraud evidence loses integrity or chain of custody

Because evidence identification, preservation, integrity checks and custody transfers are not consistently controlled, there is a risk that material evidence is altered, lost, contaminated or cannot be shown to be authentic. Consequence pathway: evidence, retention or legal-hold duties may be breached; investigations must be repeated or abandoned; recovery, disciplinary or legal outcomes are weakened; the organisation cannot substantiate its response.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

CURRENT CONTROL POSITION

Fraud Incident Response: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort

ACCOUNTABLE EXECUTIVE

Legal / investigations accountable owner / Finance / operations accountable owner

IMPACT

High — High impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

REQUIRED TREATMENT

The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.

TARGET PERIOD

60 days

RISK 4 · OPERATIONAL FRAUD CONTROLS

CRITICAL

Fictitious or conflicted supplier enters the vendor population

Because supplier identity, ownership, banking and conflict checks are incomplete or not evidenced before activation, there is a risk that a fictitious, conflicted or misrepresented supplier is approved and used for purchasing or payment. Consequence pathway: funds are paid to an illegitimate or related party; procurement and vendor-master integrity are compromised; sanctions, conflict or procurement obligations may be breached; stakeholders lose confidence in supplier governance.

LIKELIHOOD

Moderate — Critical-control, scenario or dependency evidence supports a Moderate qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Operational Fraud Controls: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

REQUIRED TREATMENT

Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks supplier-record activation until a second reviewer signs; the vendor master retains the evidence package.

TARGET PERIOD

60 days

RISK 5 · OPERATIONAL FRAUD CONTROLS, DIGITAL AND IDENTITY FRAUD RISK

CRITICAL

Unauthorised system access enables transaction or record manipulation

Because privileged, administrator or sensitive-data access is not completely restricted, logged and independently recertified, there is a risk that a privileged user or compromised administrator identity alters records, controls or logs without timely detection. Consequence pathway: confidence in digital controls is damaged; critical systems and audit trails lose integrity; high-impact transactions or data can be manipulated; security and confidentiality obligations may be breached.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Digital and Identity Fraud Risk: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort; Operational Fraud Controls: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

REQUIRED TREATMENT

IT Security must maintain a complete sensitive-access inventory, require named identities and strong authentication, enforce least privilege and session logging, and remove access when the business justification ends; periodic recertification is handled by the separate access-review control. System owners must maintain a current role-to-access matrix, require business-owner approval against the requester's current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.

ACCOUNTABLE EXECUTIVE

Technology / security accountable owner

TARGET PERIOD

60 days

RISK 6 · WHISTLEBLOWING AND REPORTING CULTURE

MEDIUM

A channel that people cannot find, do not trust or do not understand produces no reports, leaving management to believe silence means absence of fraud.

Because the self-assessment records "Employees know how to recognise suspected fraud and use the reporting channel" as "Partly designed"; the expected control standard is therefore not yet met, there is a risk that a channel that people cannot find, do not trust or do not understand produces no reports, leaving management to believe silence means absence of fraud. Consequence pathway: Early-warning information may never reach an independent reviewer; suppressed reporting lets fraud continue longer.

LIKELIHOOD

Moderate — Critical-control, scenario or dependency evidence supports a Moderate qualitative likelihood, not a statistical probability.

IMPACT

Moderate — Moderate impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Whistleblowing and Reporting Culture: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

REQUIRED TREATMENT

The ethics owner must publish channel instructions covering how to access it by phone and web, what information helps, whether anonymity is available, what feedback the reporter can expect and the protection from retaliation, in the languages and formats used across operating locations; the channel is tested at least annually with a live submission confirming intake, acknowledgement and case creation, and awareness is measured with targeted follow-up where low.

ACCOUNTABLE EXECUTIVE

People / workforce accountable owner

TARGET PERIOD

60 days

LEADERSHIP DECISIONS AND ROADMAP

Leadership decisions and roadmap

Target control environment

Strengthen fraud-risk identification and treatment

Close the process-level mapping gap by refreshing and owning a fraud-risk assessment that maps every material value-bearing process to specific fraud scenarios, the roles and permissions able to execute them, the preventive and detective controls relied upon, and residual gaps. Assign a named accountable executive and process owners, require process-owner sign-off and retain per-process maps as proof. Decisions required include naming accountable executives, choosing remediation over passive acceptance for critical risks, and approving the control-improvement standards and sequencing that will be implemented. Completion is measured when 100% of material processes have a signed fraud map with named controls and residual gaps, and any unmapped material process escalates per the approved route.

Strengthen supplier onboarding and identity checks

Implement the approved supplier pre-activation controls so that no supplier is activated without independent legal-identity, ownership, bank verification and beneficial-ownership/conflict screening. Retain the onboarding evidence package and require a second reviewer to sign before supplier-record activation. This control is owned by Finance/operations with Procurement/Vendor Master as the process owner, and proof is the completed onboarding checklist, independent verification and second-reviewer approval for every newly activated supplier. The completion test is 100% of newly activated suppliers having a pre-activation evidence pack and independent approval.

Strengthen privileged access and recertification

Reconcile and inventory all sensitive and privileged accounts, require named identities and business justification, enforce strong authentication and session logging, and recertify privileged accounts on a quarterly cycle. Remove leaver access within the agreed SLA and prohibit unjustified shared admin accounts. Technology/security should be funded to deliver this work where specialist capacity is required; management should approve the funding decision and a resource-confirmed delivery plan. Completion is demonstrated when privileged accounts are recertified quarterly, leaver access is removed within 24 hours and shared admin accounts are eliminated.

Strengthen monitoring, exception review and escalation

Operate a maintained catalogue of rules and data checks mapping each test to a named fraud scenario, ensure tests run against reconciled data and tune rules monthly from confirmed outcomes. Assign alerts to named reviewers, record investigation evidence and escalate overdue or high risk items per a published escalation criteria. The monitoring owner must reconcile the exception population and evidence assignment on a defined cycle. Completion is achieved when every priority fraud scenario has at least one operating data check and monthly tuning is completed with documented dispositions and escalations.

Strengthen evidence preservation and custody

Adopt an incident-response intake and evidence-custody standard: open an evidence register for every material case, use trained custodians to create forensic copies or sealed originals, record hashes and every transfer, and store material evidence in an access-controlled repository with retention and legal-hold instructions. Legal and investigations should govern the evidence standard and ensure trained custodians are available. Completion is measured by samples showing a complete custody trail and matching integrity checks for all material cases.

Strengthen role-based access and segregation

Require that system owners maintain a current role-to-access matrix and that access requests be approved against current duties before provisioning. Identify and either remove or document segregation-of-duties conflicts, and reconcile quarterly (and on every joiner/mover/leaver event) to the HR feed. Evidence retained should include access requests and approval trails, the role-to-access matrix and provisioning audit logs; performance is evaluated by quarterlies showing 100% population review and timely closure of removal exceptions.

Leadership decisions required

NO.	DECISION REQUIRED	RECOMMENDED DECISION	ACCOUNTABLE EXECUTIVE	TARGET PERIOD	CONSEQUENCE OF DELAY
1	Approve accountable executive mandates and escalation authority for priority remediation.	Name one accountable executive per linked control and approve a 30-day escalation route.	Finance / operations accountable owner	30 days	Priority controls remain ownerless or blocked and the maturity reading remains constrained.
2	Choose and record remediation rather than passive acceptance for Critical and High risks.	Approve linked treatments; any temporary acceptance must name an owner, expiry and compensating control.	Finance / operations accountable owner	60 days	Known risk pathways remain untreated without a documented acceptance basis.
3	Approve the target control standards management will implement across the priority risk areas.	Adopt the control-improvement register; deviations require documented oversight approval.	Finance / operations accountable owner	30 days	Partial or inconsistent designs fail to address the causal pathway.
4	Approve specialist capacity and resources for high-difficulty controls.	Fund the named supporting functions and require a resource-confirmed delivery plan.	Technology / security accountable owner	60 days	The highest-complexity gaps remain open despite nominal approval.
5	Approve prerequisite-first sequencing for dependent improvements.	Sequence dependent improvements explicitly and escalate any threatened prerequisite.	Finance / operations accountable owner	30 days	Downstream controls are implemented on incomplete foundations.
6	Approve a fixed fraud-risk implementation and control-effectiveness review cadence.	Require monthly implementation reporting and quarterly control-effectiveness review through the organisation's management and oversight route.	Finance / operations accountable owner	60 days	Actions lose momentum, exceptions remain open and management receives the control position too late to intervene.

30/60/90-day roadmap

The first 30 days establish decisions and ownership; the 60- and 90-day windows implement and evidence the linked controls.

By 30 days — Stabilise

Stabilise immediate ownership and incident-preservation mechanics. Implement the supplier pre activation checklist and blocking workflow for vendor activation, and confirm the incident-intake route with a defined evidence-preservation instruction so that any newly raised suspected matter is paused and its records held under controlled custody. The 30 day target focuses on the supplier verification steps and the minimal evidence custody intake that prevents further dispersion of potential evidence.

First 30 days — decisions and foundations

PRIORITY DECISION	DELIVERABLE	ACCOUNTABLE EXECUTIVE	COMPLETION TEST
Approve accountable executive mandates and escalation authority for priority remediation.	Name one accountable executive per linked control and approve a 30-day escalation route.	Finance / operations accountable owner	Decision recorded, accountable owner confirmed and escalation route documented.
Approve the target control standards management will implement across the priority risk areas.	Adopt the control-improvement register; deviations require documented oversight approval.	Finance / operations accountable owner	Decision recorded, accountable owner confirmed and escalation route documented.
Approve prerequisite-first sequencing for dependent improvements.	Sequence dependent improvements explicitly and escalate any threatened prerequisite.	Finance / operations accountable owner	Decision recorded, accountable owner confirmed and escalation route documented.

First 30 days — implementation foundations

DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
Operational Fraud Controls	Implement the target control design for Operational Fraud Controls. Escalation trigger: Any supplier activated before verification or any ownership/conflict match unresolved.	Finance / operations accountable owner	100% of newly activated suppliers have a complete, pre-activation evidence pack and independent approval.

By 60 days — Establish

Establish the priority preventive and access controls: reconcile the privileged-account population and begin the quarterly recertification cycle, reconcile role-based access against current responsibilities and close segregation exceptions, and implement evidence-custody forms and an evidence register for material matters. Also complete the procurement-side pre-activation proof for suppliers activated during the period. These steps convert stabilised intent into operational controls with retained proof.

60-day implementation actions

DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
Fraud Incident Response	Implement the target control design for Fraud Incident Response. Escalation trigger: Any unexplained custody gap, integrity mismatch or unauthorised repository access.	Legal / investigations accountable owner / Finance / operations accountable owner	100% of sampled material-case evidence has a complete custody trail and matching integrity check.
Operational Fraud Controls	Implement the target control design for Operational Fraud Controls. Escalation trigger: Any missed quarterly review, unassigned account or removal overdue beyond 10 business days.	Finance / operations accountable owner	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.
Digital and Identity Fraud Risk	Implement the target control design for Digital and Identity Fraud Risk. Escalation trigger: Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours.	Technology / security accountable owner	100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.
Third-Party and Supply Chain Fraud Risk	Implement the target control design for Third-Party and Supply Chain Fraud Risk. Escalation trigger: An employee-supplier match not investigated, or a declared conflict with no management action.	Finance / operations accountable owner / Legal / investigations accountable owner	At least 98% declaration completion for in-scope roles, with every identified conflict carrying an applied management action.
Whistleblowing and Reporting Culture	Implement the target control design for Whistleblowing and Reporting Culture. Escalation trigger: A failed channel test, or a site or language group below the awareness threshold.	People / workforce accountable owner	Annual live channel test passes and at least 90% of surveyed staff can describe how to submit a report.

By 90 days — Operate and review

Operate the monitoring catalogue, execute rules against reconciled data, tune tests monthly and demonstrate assigned dispositions and escalations. Complete the per-process fraud mapping cycle so that each material value-bearing process has a signed fraud map with named controls and residual gaps. Report consolidated progress into the agreed governance cadence so oversight can judge control effectiveness and delivery slippage. The first operating cycle should make coverage, review, learning and escalation visible to management.

90-day implementation actions

DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
Fraud Risk Identification	Implement the target control design for Fraud Risk Identification. Escalation trigger: Any material process unmapped, or a mapped residual gap with no owner.	Finance / operations accountable owner	100% of material value-bearing processes have a signed fraud map with named controls and residual gaps.
Fraud Detection Capability	Implement the target control design for Fraud Detection Capability. Escalation trigger: A priority scenario with no operating check, or rules unexecuted for a full cycle.	Finance / operations accountable owner / Technology / security accountable owner	All priority fraud scenarios have at least one operating data check, with monthly tuning completed.

Management conclusion

The assessment places the organisation in a Developing maturity: pockets of capability exist, notably in whistleblowing and reporting culture, but material gaps remain across process-level fraud mapping, supplier verification, privileged and role-based access governance, detection and evidence custody. Management's immediate priority is to convert the reporting-strength foundation into owned process maps, independent supplier and bank verification, disciplined privileged-access recertification and tuned monitoring with defined escalation. Those connected decisions — with named accountable executives, funded delivery where specialist skills are required, and a fixed implementation and review cadence — will interrupt the exposure pathways described and move the organisation from reactive arrangements to an evidence-backed control environment.

Proof requirements

NO.	EVIDENCE ARTEFACT	WHAT IT PROVES	LIKELY OWNER	STATUS
1	Control linkage showing preventive and detective controls	Whether each mapped fraud scenario is linked to named preventive and detective controls, with residual gaps identifiable.	Risk / compliance accountable owner with named process owners	Not yet requested
2	Per-process fraud scenario map	Whether each material process has explicit fraud scenarios, relevant roles or permissions and residual exposure documented.	Risk / compliance accountable owner with named process owners	Not yet requested
3	Process inventory identifying material value-bearing processes	Whether the complete population of material value-bearing processes has been identified before fraud-risk mapping is assessed.	Risk / compliance accountable owner with named process owners	Not yet requested
4	Process-owner sign-off	Whether process owners have reviewed and accepted the mapped fraud scenarios, control ownership and residual gaps.	Risk / compliance accountable owner with named process owners	Not yet requested
5	Beneficial-ownership/conflict screening	Whether the beneficial-ownership/conflict screening provides operating evidence that The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf is implemented across the complete in-scope population.	Procurement / Vendor Master	Not yet requested
6	Completed onboarding checklist	Whether the completed onboarding checklist provides operating evidence that The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf is implemented across the complete in-scope population.	Procurement / Vendor Master	Not yet requested
7	Independent registration and bank verification	Whether the independent registration and bank verification provides operating evidence that The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf is implemented across the complete in-scope population.	Procurement / Vendor Master	Not yet requested
8	Second-reviewer approval	Whether the second-reviewer approval provides operating evidence that The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf is implemented across the complete in-scope population.	Procurement / Vendor Master	Not yet requested
9	Approval and business justification	Whether the approval and business justification provides operating evidence that Access to sensitive systems, administrator rights and confidential data is restricted is implemented across the complete in-scope population.	Identity and Access Management	Not yet requested
10	Privileged-account register	Whether the privileged-account register provides operating evidence that Access to sensitive systems, administrator rights and confidential data is restricted is implemented across the complete in-scope population.	Identity and Access Management	Not yet requested
11	Privileged-session/access logs	Whether the privileged-session/access logs provides operating evidence that Access to sensitive systems, administrator rights and confidential data is restricted is implemented across the complete in-scope population.	Identity and Access Management	Not yet requested
12	Quarterly independent recertification	Whether the quarterly independent recertification provides operating evidence that Access to sensitive systems, administrator rights and confidential data is restricted is implemented across the complete in-scope population.	Identity and Access Management	Not yet requested
13	Removal tickets	Whether the removal tickets provides operating evidence that Access to sensitive systems, administrator rights and confidential data is restricted is implemented across the complete in-scope population.	Identity and Access Management	Not yet requested

NO.	EVIDENCE ARTEFACT	WHAT IT PROVES	LIKELY OWNER	STATUS
14	Chain-of-custody forms	Whether each transfer of material evidence records custody, timing and handover without unexplained gaps.	Investigation lead / Evidence custodian	Not yet requested
15	Evidence register	Whether all material evidence items are uniquely recorded, assigned and traceable through the case.	Investigation lead / Evidence custodian	Not yet requested

Required population for every item: the complete in-scope population for the stated operating period, reconciled to the source system or register. Sampling expectation: review the complete population where feasible; otherwise use a documented risk-based sample including exceptions, changes and overdue items. Every item begins with the status "Not yet requested"; status changes require a separately scoped review process outside this report. This remains a self-assessment: no document, interview, transaction sample or system evidence has been independently verified for any item.

METHODOLOGY, LIMITATIONS AND NEXT STEPS

Methodology, limitations and next steps

This report is generated from a structured self-assessment across ten fraud-risk-management domains. The score, maturity ceilings and advisory model use only the recorded assessment inputs and the MK Fraud Readiness methodology.

Limitations. This is not a forensic investigation, external audit, compliance certification or guarantee. Responses were not independently verified. Findings, scenarios and recommendations are decision-support material; leadership should obtain the specified operating proof before treating a control as effective or a finding as resolved.

Control design standard. Priority controls are specified by responsibility, population or scope, operating frequency, retained evidence, independent challenge, escalation trigger, service level, effectiveness measure and response to failure.

Assessment basis: submitted self-assessment responses and the MK Fraud Readiness methodology.

APPENDIX

Appendix: supporting material

Complete supporting detail

This report presents the highest-priority matters from a complete assessment inventory of 68 controls (60 applicable and 8 excluded). The full assessment identified 25 material findings, 24 risks, 25 control improvements, 105 evidence artefacts, 25 recommended actions and 59 functional-agenda items.

E1. Supporting control actions

Further control actions beyond the priority set above, in materiality order.

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
1	Operational Fraud Controls	Close the material control weakness recorded for "Transactions or operational activities above defined risk or value thresholds require independent review or approval".	The Finance / operations accountable owner must approve a delegation of authority matrix setting value and risk thresholds by transaction type, configure the finance and operational systems to block release above threshold without a second independent approver, prohibit self-approval and approval by direct reports of the initiator, and run a monthly report for split transactions falling just below thresholds and for any threshold override.	Finance / operations accountable owner / 60 days
2	Operational Fraud Controls	Close the material control weakness recorded for "People in high-risk roles are subject to appropriate oversight, rotation, secondary review or other compensating controls".	Human Resources and the Risk / compliance accountable owner must jointly define high-risk roles by authority, system access and asset custody, and apply documented measures to each: secondary review of sensitive outputs, periodic rotation or cross-training, a block-leave or cover period during which another person performs the duties, and enhanced transaction monitoring; measures are applied consistently, recorded, and reviewed annually for coverage and fairness.	Finance / operations accountable owner / People / workforce accountable owner / 90 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
3	Fraud Detection Capability	Close the material control weakness recorded for "Exception reporting provides defined alerts for unusual transactions or activities and a documented review process".	The monitoring owner generates a complete daily or weekly exception queue, assigns each alert to a trained reviewer, records investigation evidence and disposition, and escalates high-risk alerts immediately and all overdue alerts weekly; Risk performs a monthly closure-quality sample.	Finance / operations accountable owner / 60 days
4	Fraud Detection Capability	Close the material control weakness recorded for "Monitoring covers fraud and control misuse by people inside the organisation".	The monitoring owner must define internal-misuse scenarios for privileged use, overrides, unusual approvals, manual adjustments and other value-bearing activity; reconcile the monitored population to source systems, assign alerts to an independent reviewer and retain disposition and escalation evidence.	Finance / operations accountable owner / Technology / security accountable owner / 90 days
5	Fraud Detection Capability	Close the material control weakness recorded for "Monitoring covers fraud threats from external parties relevant to the organisation".	The fraud-monitoring owner must identify relevant external-party threats across customer, supplier, partner and provider-operated channels, define required provider reports and data quality checks, reconcile those reports to the organisation's own systems where possible, and route exceptions into owned triage and escalation.	Finance / operations accountable owner / Technology / security accountable owner / 90 days
6	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Fraud risks are considered when using agents, brokers, distributors, intermediaries, partners or outsourced service providers where relevant".	The relationship owner must ensure every intermediary or outsourced arrangement defines in contract the fraud-control obligations, the limits of delegated authority, the right to audit and obtain records, incident-notification duties and consequences for breach; oversight includes reconciliation of transactions and collections handled on the organisation's behalf, periodic assurance over the provider's relevant controls, and review of any sub-contracting before it occurs.	Finance / operations accountable owner / 90 days
7	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Sensitive access and administrator rights are reviewed periodically".	IT Security must reconcile the complete sensitive-access and administrator population to current owners and role requirements at least quarterly, obtain an independent keep/remove decision from system owners, record exceptions and close removals within the defined service level; emergency and service accounts are included.	Technology / security accountable owner / 60 days
8	Operational Fraud Controls	Close the material control weakness recorded for "System and data access is reviewed periodically and removed when no longer required".	System owners must export the complete active-user access population on a defined cycle, obtain business-owner keep/remove decisions against current responsibilities, route exceptions to IT for closure and reconcile leaver and mover removals to the HR feed.	Finance / operations accountable owner / 60 days
9	Operational Fraud Controls	Close the material control weakness recorded for "Payroll master-file changes and unusual payroll records receive review before payment".	Payroll and Human Resources must reconcile joiner, mover and leaver records to the payroll master file before each payment run, independently review bank-account and pay-rate changes, test for duplicate or ghost records and unusual payments, and retain reviewer decisions and exception closure before release.	Finance / operations accountable owner / People / workforce accountable owner / 60 days
10	Operational Fraud Controls	Close the material control weakness recorded for "Physical cash is counted, safeguarded and reconciled by defined people".	Finance and site managers must assign cash custodians, perform opening and closing counts with independent review, reconcile takings to receipts and bankings, record sealed transfers and investigate every shortage or overage against a defined threshold before the next cycle closes.	Finance / operations accountable owner / 60 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
11	Operational Fraud Controls	Close the material control weakness recorded for "held assets and physical assets are safeguarded and reconciled by defined people".	Operations and Finance must maintain a complete held assets and asset register, assign custodians, require authorised movement and disposal records, perform risk-based counts across locations, reconcile results to the ledger or inventory system and independently approve write-offs and investigate shrinkage exceptions.	Finance / operations accountable owner / 90 days
12	Fraud Detection Capability	Close the material control weakness recorded for "People responsible for monitoring suspicious activity know when to escalate concerns and have authority to do so".	The Risk / compliance accountable owner must publish escalation criteria defining what must be escalated, to whom and within what time, grant monitoring staff explicit authority to escalate directly to the fraud-risk executive or Governing body / independent oversight where a manager is implicated, protect escalators from retaliation, train the monitoring team annually, and review escalation timeliness against criteria each quarter.	Risk / compliance accountable owner / 30 days
13	Fraud Detection Capability	Close the material control weakness recorded for "Detection controls are periodically reviewed for effectiveness by management, risk, audit or another independent reviewer".	The Governing body / independent oversight must commission a periodic independent evaluation of detection effectiveness covering coverage against the process fraud maps, data completeness, sample retesting of closed alerts for closure quality, and detection of deliberately seeded test conditions where practical; findings are reported to governance with owners and due dates, and remediation is tracked to closure.	Governing body / independent oversight / 90 days
14	Fraud Incident Response	Close the material control weakness recorded for "Roles and decision rights are defined for fraud triage, investigation, escalation and case closure".	The incident-response lead must maintain a decision-rights matrix covering intake, severity, triage, investigation, escalation, disciplinary or recovery referral and closure; conflicts are recorded, independent challenge is available and every decision is retained in the case record.	Finance / operations accountable owner / Legal / investigations accountable owner / 30 days
15	Fraud Incident Response	Close the material control weakness recorded for "External specialists are considered when incidents require forensic, legal, cyber or investigative expertise".	The incident-response lead must define engagement triggers such as suspected loss above a threshold, digital forensic imaging requirements, senior-management or governing-body involvement, cross-border elements or likely litigation; pre-qualify providers for forensic accounting, digital forensics and investigative legal support with confidentiality, privilege, data-protection and evidential-standard terms agreed in advance, and record the decision to engage or not engage in every qualifying case.	Legal / investigations accountable owner / Finance / operations accountable owner / 60 days
16	Whistleblowing and Reporting Culture	Close the material control weakness recorded for "Relevant external stakeholders have an appropriate way to report suspected fraud or misconduct".	The ethics owner must publish the external reporting route for each relevant stakeholder group, state confidentiality and anti-retaliation protections, restrict access to reports, route concerns away from implicated managers and monitor acknowledgement, triage and escalation times.	Governing body / independent oversight / CEO / 60 days
17	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "The organisation receives and reviews risk information about high-risk third parties managed on its behalf".	The vendor-risk owner must define a risk-based monitoring cycle in which high-risk third parties are re-screened for ownership and sanctions change, reviewed for delivery and quality performance, tested for pricing drift against benchmark or contract, and analysed for spend concentration and unusual growth; findings requiring action are logged with owners, and failure to complete a cycle triggers escalation to the Finance / operations accountable owner.	Finance / operations accountable owner / 90 days

E2. Definitions and score basis

How the score is calculated

Each applicable assessment response is normalised to a 0–100 control score and weighted within its domain. Domain scores are then combined using the methodology's domain weights to produce the overall readiness score. A control recorded as not applicable is excluded from its scoring denominator rather than treated as a weakness.

The weighted overall score is 43.33/100, which maps numerically to Developing. The final maturity shown in this report is Developing. The next numerical band begins at 60/100; a higher numerical score alone does not override a stricter applicable maturity ceiling.

Maturity scale

Maturity	Score Range	Interpretation
Reactive	0–<40	Foundational controls are limited or mainly reactive.
Developing	40–<60	Core control elements exist but are incomplete, inconsistent or not yet connected.
Structured	60–<80	Controls are more consistently defined, owned and operated.
Strategic	80–100	Fraud-risk management is embedded, monitored and continually improved.

Maturity ceilings

Maturity ceilings protect against a strong average masking a material weakness. A hard-gate critical control scored 0 or 1 sets a maximum of Developing; a hard-gate control scored 2 sets a maximum of Structured; three or more critical controls scored 0, 1 or 2 set a maximum of Developing; any core domain below 40 sets a maximum of Developing; and any core domain below 60 sets a maximum of Structured. Where several ceilings apply, the strictest ceiling governs the final maturity.

Reported domain scores

Domain	Reported Score	Maturity
Fraud Leadership and Governance	42/100	Developing
Fraud Risk Identification	39/100	Reactive
Operational Fraud Controls	41/100	Developing
Fraud Detection Capability	41/100	Developing
Fraud Incident Response	44/100	Developing
Whistleblowing and Reporting Culture	61/100	Structured
Third-Party and Supply Chain Fraud Risk	47/100	Developing
Digital and Identity Fraud Risk	38/100	Reactive
Fraud Culture and Awareness	57/100	Developing
Continuous Improvement and Fraud Risk Monitoring	41/100	Developing

Risk priority uses the deterministic qualitative likelihood/impact matrix. Risks in the same priority class are not further ranked by their display sequence. Priority and materiality are derived from assessment evidence; neither is an independent risk assessment.